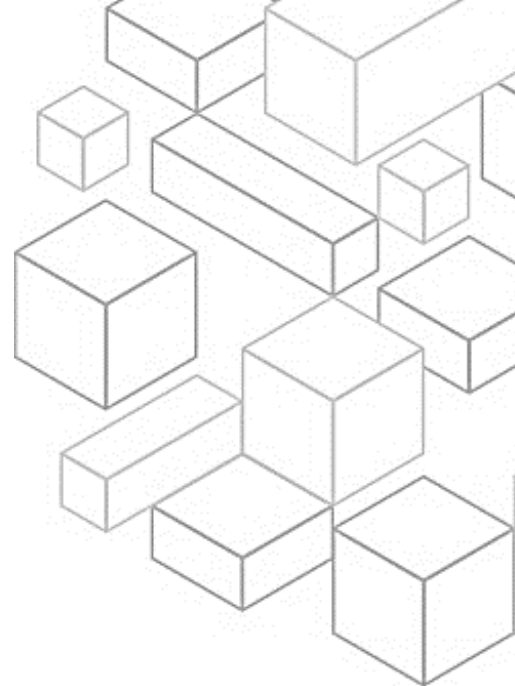




Module 5 Deep Dive on the Security Pillar

1.1 AWS Well-Architected

Welcome to module five of AWS Well-Architected - Deep Dive on the Security Pillar.

1.2 Learning objectives

In this module, you will get an overview of the security pillar of the AWS Well-Architected Framework. You will also learn the design principles and best practices of the security pillar.

1.3 Security Pillar Overview

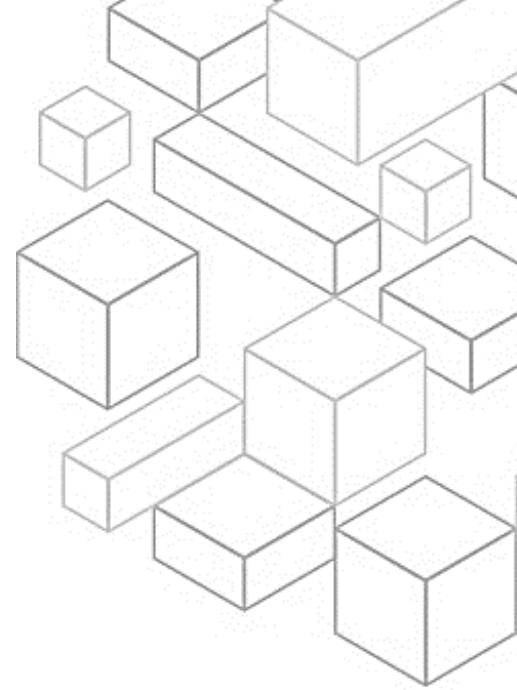
To begin, you will get an overview of the security pillar.

1.4 Pillars of Well-Architected

There are currently six pillars in the Well-Architected Framework: operational excellence, security, reliability, performance efficiency, cost optimization, and sustainability. These pillars are the foundations of the architecture for your technology solutions in the cloud. This module will focus on the security pillar.

1.5 What is the security pillar?

The security pillar encompasses the ability to protect data, systems, and assets on the cloud. To operate your workload securely, you must apply overarching best practices to every area of security.



1.6 Security Design Principles

Now that you understand what the security pillar is, you will dive deeper into the design principles of the security pillar.

1.7 Security

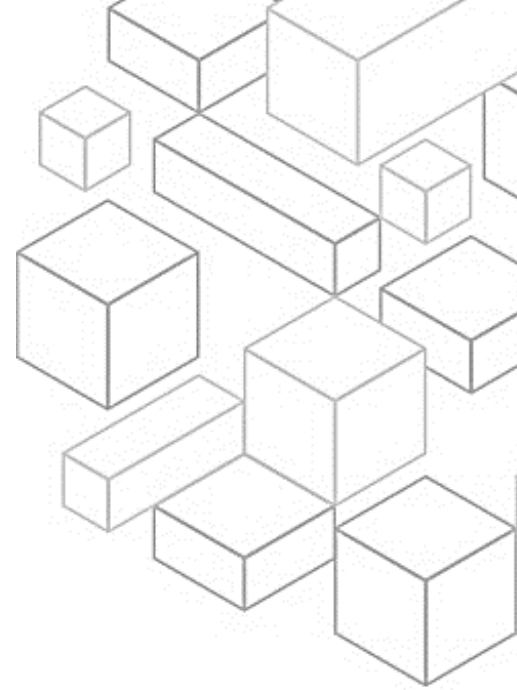
In the cloud, a number of principles can help you strengthen your workload security. First, implement a strong identity foundation. You can implement the principle of least privilege and enforce separation of duties with appropriate authorization for each interaction with your AWS resources. Centralize identity management, and aim to eliminate reliance on long-term and static credentials.

Second, turn on traceability. You can monitor, alert, and audit actions and changes to your environment in real time. Integrate log and metric collection with systems to automatically investigate and take actions.

Third, apply security at all layers. Apply a defense-in-depth approach with multiple security controls. Apply controls to all layers, such as edge of network, virtual private cloud or VPC, load balancing, compute instances, operating systems, applications, and code.

Fourth, automate security best practices. Automated software-based security mechanisms improve your ability to securely scale more rapidly and cost effectively. Create secure architectures, including implementing controls that are defined and managed as code in version-controlled templates.

Fifth, protect data in transit and at rest. Classify your data into sensitivity levels and use mechanisms, such as encryption, tokenization, and access control where appropriate.



Sixth, keep people away from data. Use mechanisms and tools to reduce or eliminate the need for direct access or manual processing of data. This decreases the risk of mishandling or human error with sensitive data.

Finally, prepare for security events. Prepare for an incident by having incident management and investigation policy and processes that align to your organizational requirements. Run incident response simulations and use automated tools to speed your detection, investigation, and recovery.

1.8 Security Best Practices

Now that you understand the security design principles, you will learn about the security best practices.

1.9 Security

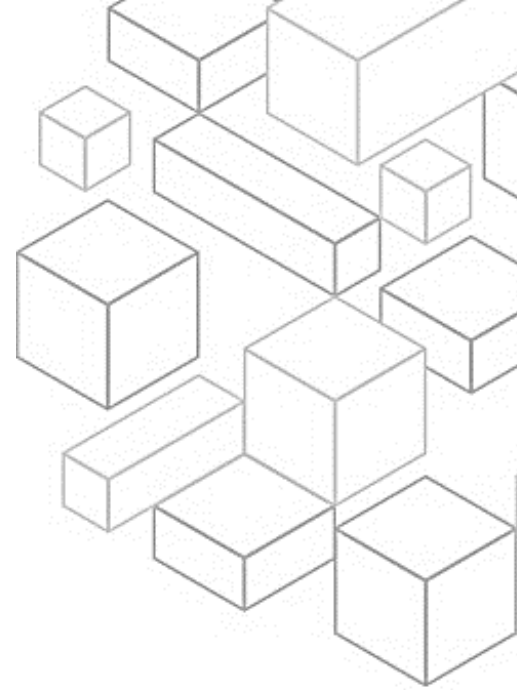
The security pillar is grouped into seven areas of best practices. These include security foundations, identity and access management, detection, infrastructure protection, data protection, incident response, and application security.

1.10 Security Foundations

Security foundations is the first security best practice area.

1.11 Shared responsibility

Security and compliance is a shared responsibility between AWS and the customer. This shared model can help relieve the customer's operational burden as AWS operates, manages, and controls the components from the host



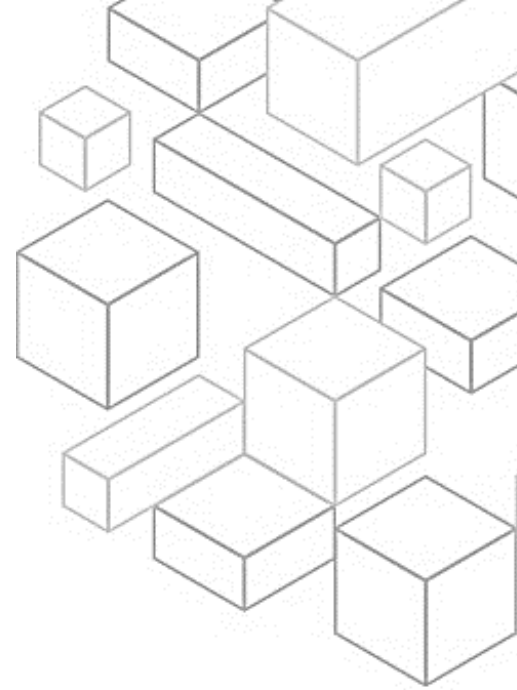
operating system and virtualization layer down to the physical security of the facilities in which the service operates.

The customer assumes responsibility and management of the guest operating system (including updates and security patches) and other associated application software. The customer is also responsible for the configuration of the AWS security group firewall. Customers should carefully consider the services they choose. Responsibilities vary depending on the services used, the integration of those services into their IT environment, and applicable laws and regulations.

The nature of this shared responsibility also provides the flexibility and customer control that permits the deployment. As shown in the chart, this differentiation of responsibility is commonly referred to as security “of” the cloud compared to security “in” the cloud.

AWS is responsible for security of the cloud, protecting the infrastructure that runs all services offered in the AWS Cloud. This infrastructure is composed of the hardware, software, networking, and facilities that run AWS Cloud services.

The customer is responsible for security in the cloud. Customer responsibility depends on their selected AWS Cloud services. This determines the amount of configuration work the customer must perform as part of their security responsibilities. For example, a service such as Amazon Elastic Compute Cloud, or Amazon EC2, is categorized as infrastructure as a service. As such, it requires the customer to perform all necessary security configuration and management tasks. Customers who deploy an EC2 instance are responsible for managing the guest operating system (including updates and security patches) and any application software or utilities they install on the instances. They would also



be responsible for the configuration of the firewall provided by AWS, or security group, on each instance. For abstracted services, such as Amazon Simple Storage Service, or Amazon S3, and Amazon DynamoDB, AWS operates the infrastructure layer, operating system, and platforms. Customers access the endpoints to store and retrieve data. Customers are responsible for managing their data (including encryption options), classifying their assets, and using AWS Identity and Access Management, or IAM, tools to apply the appropriate permissions.

1.12 AWS account management and separation

It is a best practice to organize workloads in separate accounts and group accounts. This can be based on function, compliance requirements, or a common set of controls rather than mirroring your organization's reporting structure. In AWS, accounts are a hard boundary. For example, account-level separation is strongly recommended to isolate production workloads from development and test workloads. You should manage accounts, set controls, and configure services and resources centrally. To separate workloads using accounts, you can establish common guardrails and isolation between environments (such as production, development, and test) and workloads through a multi-account strategy. Account-level separation is strongly recommended because it provides a strong isolation boundary for security, billing, and access.

You should also secure the account root user and properties. The root user is the most privileged user in an AWS account, with full administrative access to all resources in the account. In some cases, it cannot be constrained by security policies. You can take the following actions to help reduce the risk of



inadvertent exposure of root credentials and subsequent compromise of the cloud environment. Deactivate programmatic access to the root user, establish appropriate controls for the root user, and avoid routine use of the root user.

1.13 Operating your workloads securely

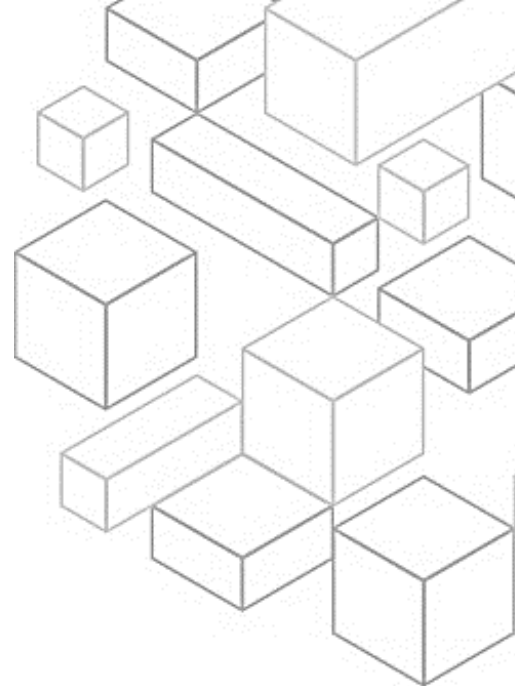
To operate your workload securely, you must apply overarching best practices to every area of security. Take requirements and processes that you have defined in operational excellence at an organizational and workload level, and apply them to all areas. Staying up to date with AWS and industry recommendations and threat intelligence helps you evolve your threat model and control objectives. Automating security processes, testing, and validation helps you scale your security operations. Consider the following best practices for operating your workload securely.

First, identify and validate control objectives. Based on your compliance requirements and risks identified from your threat model, derive and validate the control objectives and controls that you need to apply to your workload. Ongoing validation of control objectives and controls help you measure the effectiveness of risk mitigation.

To help you define and implement appropriate controls, recognize attack vectors by staying up to date with the latest security threats.

Stay current with both AWS and industry security recommendations to evolve the security posture of your workload.

Automate testing and validation of security controls in pipelines. Establish secure baselines and templates for security mechanisms that are tested and



validated as part of your build, pipelines, and processes. Use tools and automation to test and validate all security controls continuously.

Identify threats and prioritize mitigations using a threat model. Perform threat modeling to identify and maintain an up-to-date register of potential threats and associated mitigations for your workload. Prioritize your threats and adapt your security control mitigations to prevent, detect, and respond. Revisit and maintain this in the context of your workload and the evolving security landscape.

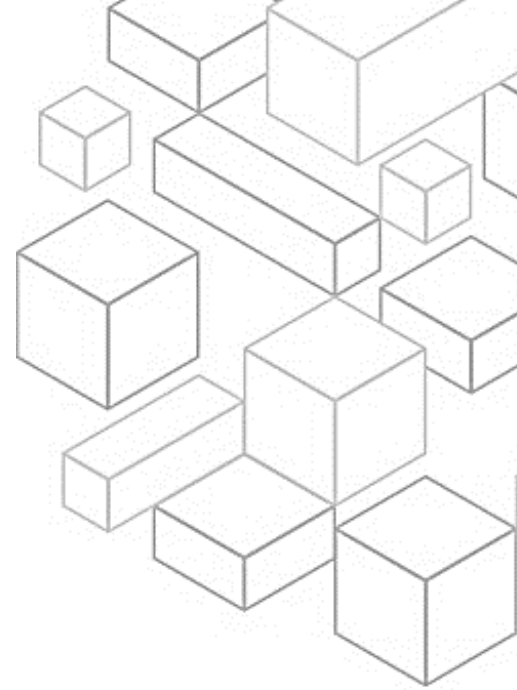
Evaluate and implement security services and features from AWS and AWS Partners to help you evolve the security posture of your workload.

1.14 Identity and Access Management

The next security best practice area is identity and access management. To use AWS services, you must grant your users and applications access to resources in your AWS accounts. As you run more workloads on AWS, you need robust identity management and permissions in place to ensure that the right people have access to the right resources under the right conditions. AWS offers a large selection of capabilities to help you manage your human and machine identities and their permissions. The best practices for these capabilities fall into two main areas: identity management and permissions management.

1.15 Identity management

There are two types of identities you need to manage when approaching how to operate secure AWS workloads. First, human identities: The administrators, developers, operators, and consumers of your applications require an identity to access your AWS environments and applications. These can be members of

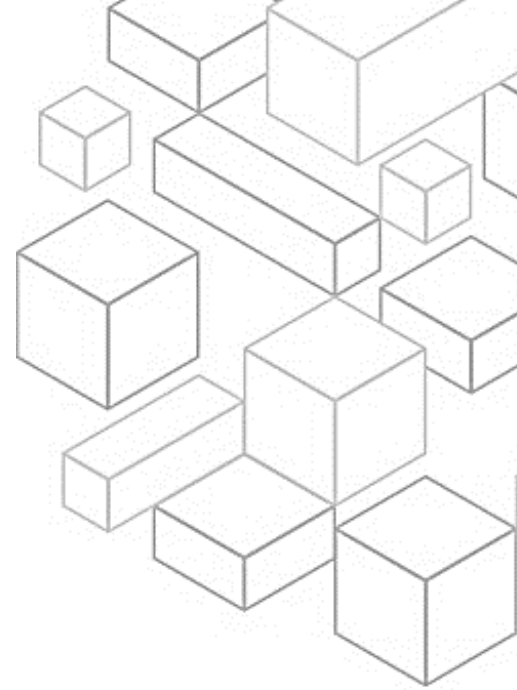


your organization or external users with whom you collaborate. They interact with your AWS resources through a web browser, client application, mobile app, or interactive command-line tools.

Second, machine identities: Your workload applications, operational tools, and components require an identity to make requests to AWS services, such as to read data. These identities include machines running in your AWS environment, such as EC2 instances or AWS Lambda functions. You can also manage machine identities for external parties who need access. Additionally, you might have machines outside of AWS that need access to your AWS environment. There are several best practices for managing identities, such as using strong sign-in mechanisms. Authentication with sign-in credentials can present risks when not using mechanisms like multi-factor authentication, or MFA. This is especially true in situations where sign-in credentials have been inadvertently disclosed or are easily guessed. Sign-in mechanisms can help reduce these risks by requiring MFA and strong password policies.

It's also best to employ temporary credentials to authenticate instead of long-term credentials. This helps reduce or eliminate risks, such as credentials being inadvertently disclosed, shared, or stolen.

You can also store and use secrets securely. A workload requires an automated capability to prove its identity to databases, resources, and third-party services. This is accomplished using secret access credentials, such as API access keys, passwords, and OAuth tokens. Using a purpose-built service to store, manage, and rotate these credentials helps reduce the likelihood that those credentials become compromised.



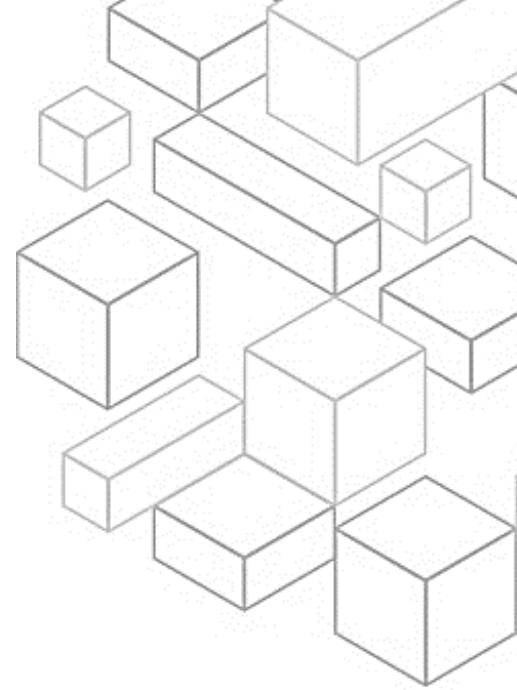
For workforce identities, rely on an identity provider that helps you manage identities in a centralized place. This makes it easier to manage access across multiple applications and services because you are creating, managing, and revoking access from a single location.

Audit and rotate credentials periodically to limit how long the credentials can be used to access your resources. Long-term credentials create many risks, and these risks can be reduced by rotating long-term credentials regularly.

As the number of users you manage grows, you will need to determine ways to organize them so that you can manage them at scale. Place users with common security requirements in groups defined by your identity provider. Put mechanisms in place to ensure that user attributes that may be used for access control, such as department or location, are correct and updated. Use these groups and attributes to control access rather than individual users. This helps you manage access centrally by changing a user's group membership or attributes once with a permission set. You avoid having to update many individual policies when a user's access needs to be changed.

1.16 Permissions management

Manage permissions to control access to human and machine identities that require access to AWS and your workloads. Permissions control who can access what and under what conditions. Set permissions to specific human and machine identities to grant access to specific service actions on specific resources. Additionally, specify conditions that must be true for access to be granted. For example, you can allow developers to create new Lambda functions, but only in a specific Region.



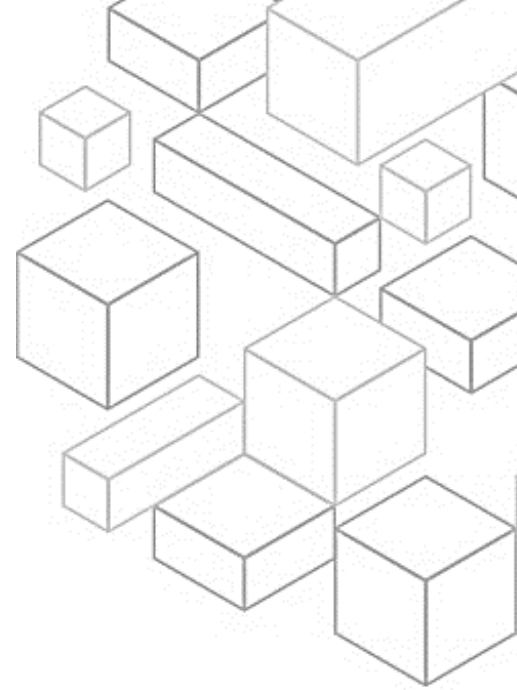
When managing your AWS environments at scale, adhere to the following best practices to ensure that identities only have the access they need and nothing more. Each component or resource of your workload needs to be accessed by administrators, end users, or other components. Have a clear definition of who or what should have access to each component. Choose the appropriate identity type and method of authentication and authorization.

It's a best practice to grant only the access that identities require to perform specific actions on specific resources under specific conditions. Use group and identity attributes to dynamically set permissions at scale, rather than defining permissions for individual users. For example, you can allow a group of developers access to manage only resources for their project. This way, if a developer leaves the project, the developer's access is automatically revoked without changing the underlying access policies.

You can also consider a process that gives emergency access to your workload in the unlikely event of an automated process or pipeline issue. This will help you rely on least privilege access, but ensure that users can obtain the right level of access when they require it.

As teams and workloads determine what access they need, remove permissions they no longer use and establish review processes to achieve least privilege permissions. Continuously monitor and reduce unused identities and permissions.

Define permission guardrails for your organization, and establish common controls that restrict access to all identities in your organization.



You can also manage access based on lifecycle. Integrate access controls with operator and application lifecycle and your centralized federation provider.

To analyze public and cross-account access, continuously monitor findings that highlight public and cross-account access. Reduce public access and cross-account access to only resources that require this type of access.

As the number of workloads grows, you might need to share access to resources in those workloads or provision the resources multiple times across multiple accounts. You might have constructs to compartmentalize your environment, such as having development, testing, and production environments. However, having separation constructs does not limit you from being able to share securely. By sharing components that overlap, you can reduce operational overhead and create a consistent experience without guessing what you might have missed while creating the same resource multiple times.

The security of your cloud environment doesn't stop at your organization. Your organization might rely on a third party to manage a portion of your data. The permission management for the third-party managed system should follow the practice of just-in-time access using the principle of least privilege with temporary credentials. By working closely with a third party, you can reduce the scope of impact and risk of unintended access together.

1.17 Detection

The next security best practice area is detection. You can use detective controls to identify a potential security threat or incident. They are an essential part of



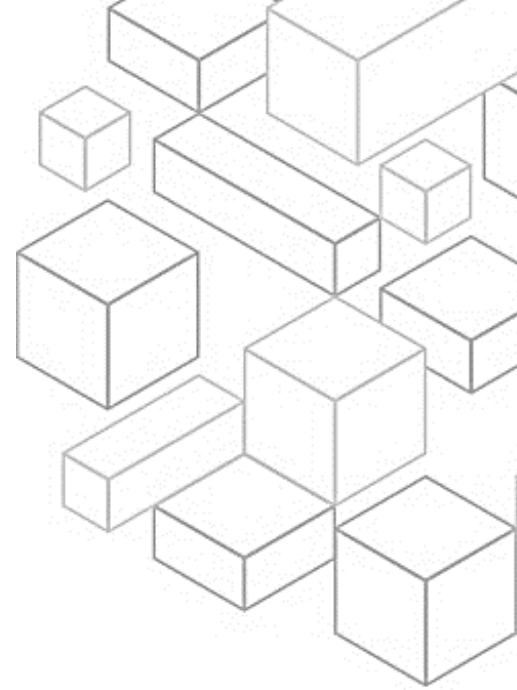
governance frameworks and can be used to support a quality process, a legal or compliance obligation, and for threat identification and response efforts.

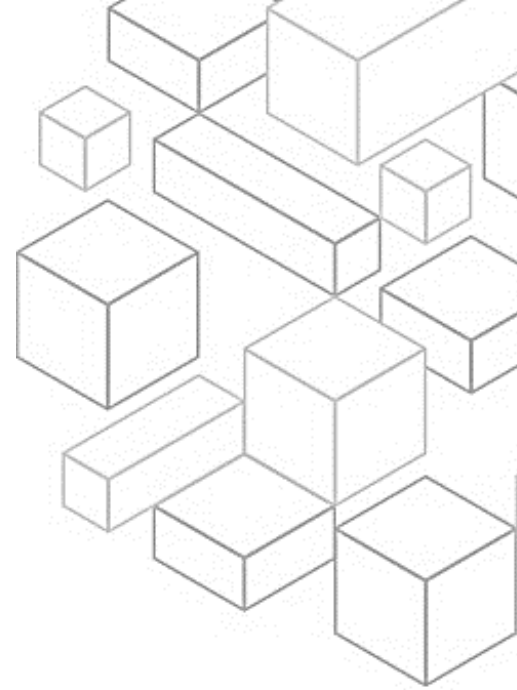
1.18 Detection

Detection consists of two parts: detection of unexpected or unwanted configuration changes, and the detection of unexpected behavior. Detection helps you identify a potential security misconfiguration, threat, or unexpected behavior. It's an essential part of the security lifecycle and can be used to support a quality process, a legal or compliance obligation, and for threat identification and response efforts. For AWS, there are a number of approaches you can use when addressing detective mechanisms. The following are detection best practices.

First, configure service and application logging. Retain security event logs from services and applications. This is a fundamental principle of security for audit, investigations, and operational use cases. It is a common security requirement driven by governance, risk, and compliance, or GRC, standards, policies, and procedures.

Next, analyze logs, findings, and metrics centrally. Security operations teams rely on the collection of logs and the use of search tools to discover potential events of interest that might indicate unauthorized activity or unintentional change. However, simply analyzing collected data and manually processing information is insufficient to keep up with the volume of information flowing from complex architectures. Analysis and reporting alone don't facilitate the assignment of the right resources to work an event in a timely fashion.





Third, automate responses to events. Using automation to investigate and remediate events reduces human effort and error and helps you scale investigation capabilities.

Through regular reviews, you can tune automation tools and continuously iterate.

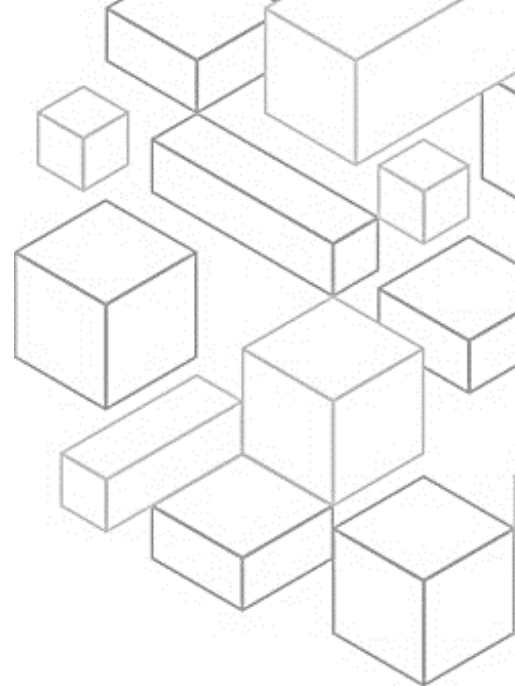
Finally, implement actionable security events. Create alerts that are sent to and can be actioned by your team. Ensure that alerts include relevant information for the team to take action. For each detective mechanism you have, you should also have a process, in the form of a runbook or playbook, to investigate.

1.19 Infrastructure Protection

The next security best practice area is infrastructure protection. Infrastructure protection encompasses control methodologies, such as defense in depth, that are necessary to meet best practices and organizational or regulatory obligations. Use of these methodologies is critical for successful ongoing operations in the cloud. Infrastructure protection is a key part of an information security program. It helps ensure that systems and services in your workload are protected against unintended and unauthorized access and potential vulnerabilities.

1.20 Protecting networks

Users, both in your workforce and your customers, can be located anywhere. You need to pivot from traditional models of trusting anyone and anything that has access to your network. When you follow the principle of applying security at all layers, you employ a Zero Trust approach. Zero Trust security is a model where application components or microservices are considered discrete



from each other, and no component or microservice trusts any other. The following are best practices for protecting networks.

First, create network layers. Group components that share sensitivity requirements into layers to minimize the potential scope of impact of unauthorized access.

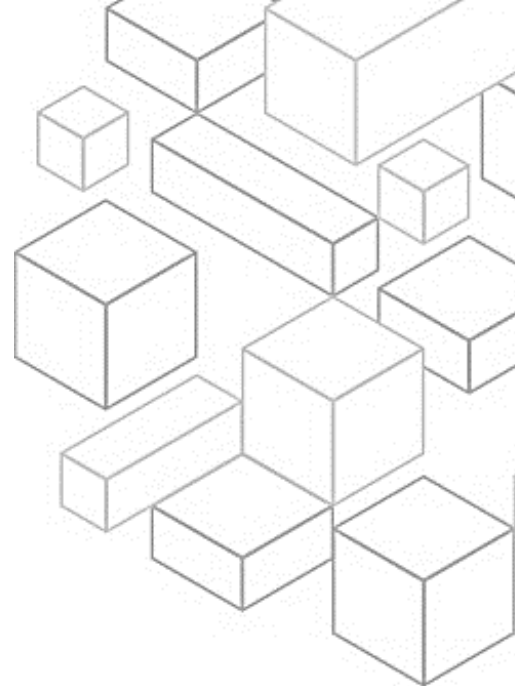
Next, control traffic at all layers. When architecting your network topology, you should examine the connectivity requirements of each component.

Third, automate network protection mechanisms to provide a self-defending network based on threat intelligence and anomaly detection.

Finally, implement inspection and protection. Inspect and filter your traffic at each layer.

1.21 Protecting compute

Compute resources include EC2 instances, containers, Lambda functions, database services, Internet of Things devices, and more. Each of these compute resource types require different approaches to secure them. However, they do share common strategies that you need to consider: defense in depth, vulnerability management, reduction in attack surface, automation of configuration and operation, and performing actions at a distance. In this section, you will find general guidance for protecting your compute resources for key services. For each AWS service used, it's important for you to check the specific security recommendations in the service documentation. The following are the best practices for protecting compute resources:



Perform vulnerability management. Frequently scan and patch for vulnerabilities in your code, dependencies, and in your infrastructure to help protect against new threats.

Reduce attack surface. Limit your exposure to unintended access by hardening operating systems and minimizing the components, libraries, and externally consumable services in use.

Implement services that manage resources, such as Amazon Relational Database Service, or Amazon RDS, Lambda, and Amazon Elastic Container Service, or Amazon ECS. These can help reduce your security maintenance tasks as part of the shared responsibility model.

Automate your protective compute mechanisms including vulnerability management, reduction in attack surface, and management of resources. The automation will help you invest time in securing other aspects of your workload, and reduce the risk of human error.

Help people perform actions at a distance. Removing the ability for interactive access reduces the risk of human error and the potential for manual configuration or management.

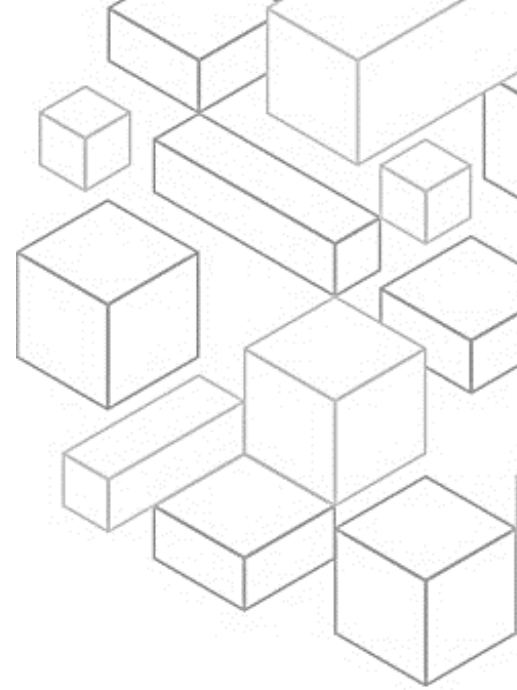
Implement mechanisms such as code signing to validate that the software, code, and libraries used in the workload are from trusted sources and have not been tampered with.

1.22 Data Protection

The next security best practice area is data protection. Before architecting any workload, foundational practices that influence security should be in place. For example, data classification provides a way to categorize data based on levels of sensitivity. Encryption protects data by rendering it unintelligible to



unauthorized access. These methods are important because they support objectives such as limiting mishandling or helping comply with regulatory obligations. With AWS, there are a number of different approaches you can use when addressing data protection. The following section describes how to use these approaches.



1.23 Classifying data

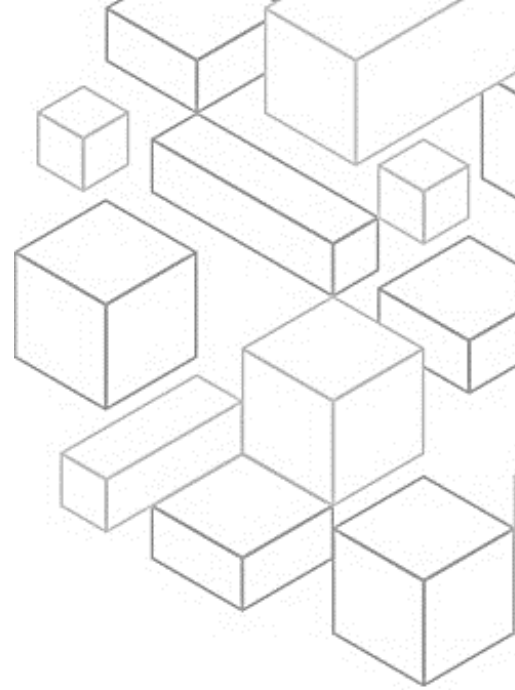
Data classification provides a way to categorize organizational data based on criticality and sensitivity. This can help you determine appropriate protection and retention controls.

Identify the data in your workload. It is critical to understand the type and classification of data your workload is processing, the associated business processes, where the data is stored, and who the data owner is. You should also have an understanding of the applicable legal and compliance requirements of your workload, and what data controls need to be enforced.

Identifying data is the first step in the data classification journey. It is important to define data protection controls. You can protect data according to its classification level.

Automating the identification and classification of data can help you implement the correct controls. Using automation for this instead of direct access from a person reduces the risk of human error and exposure.

You can also define data lifecycle management. Your defined lifecycle strategy should be based on sensitivity level along with legal and organization requirements. Aspects including the duration for which you retain data, data destruction processes, data access management, data transformation, and data sharing should be considered.



1.24 Protecting data at rest

Data at rest represents any data that you persist in nonvolatile storage for any duration in your workload. This includes block storage, object storage, databases, archives, IoT devices, and any other storage medium on which data is persisted. Protecting your data at rest reduces the risk of unauthorized access, when encryption and appropriate access controls are implemented. Consider the following best practices for protecting data at rest.

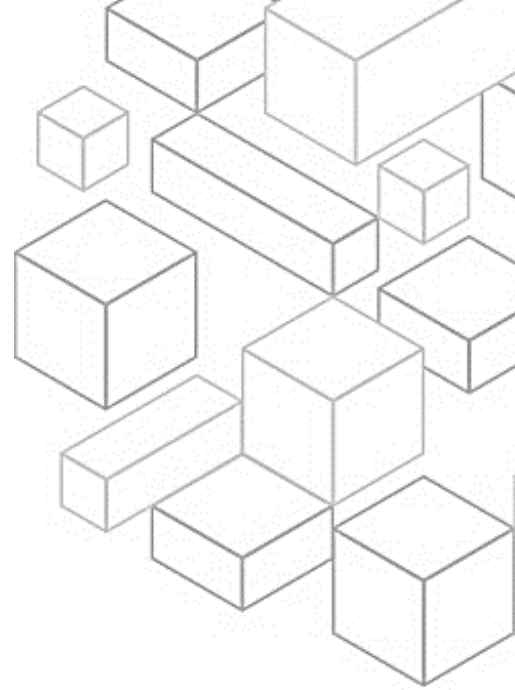
First, implement secure key management. Define an encryption approach that includes the storage, rotation, and access control of keys. This can help you protect content against unauthorized users and unnecessary exposure to authorized users.

Next, enforce encryption at rest. You should enforce the use of encryption for data at rest. Encryption maintains the confidentiality of sensitive data in the event of unauthorized access or accidental disclosure.

You can also automate data-at-rest protection using automated tools to validate and enforce data-at-rest controls continuously.

Enforce access control. To help protect your data at rest, enforce access control using mechanisms, such as isolation and versioning, and apply the principle of least privilege. Prevent the granting of public access to your data.

Finally, use mechanisms to distance people from data. Keep all users away from directly accessing sensitive data and systems under normal operational circumstances.



1.25 Protecting data in transit

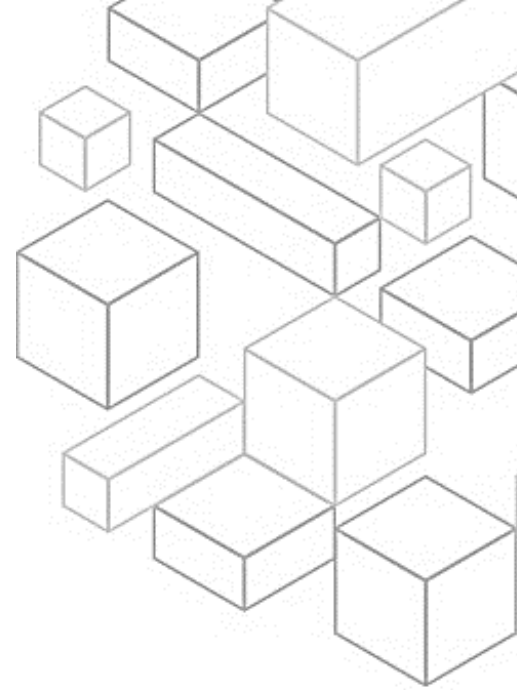
Data in transit is any data that is sent from one system to another. This includes communication between resources in your workload and also communication between other services and your end users. By providing the appropriate level of protection for data in transit, you protect the confidentiality and integrity of your workload's data. Consider the following best practices for protecting data in transit.

First, implement secure key and certificate management. Store encryption keys and certificates securely, and rotate them at appropriate time intervals with strict access control.

Second, enforce encryption in transit. Enforce your defined encryption requirements based on your organization's policies, regulatory obligations, and standards to help meet organizational, legal, and compliance requirements. Only use protocols with encryption when transmitting sensitive data outside of your VPC. Encryption helps maintain data confidentiality even when the data transits untrusted networks.

Third, automate detection of unintended data access. Use tools such as Amazon GuardDuty to automatically detect suspicious activity or attempts to move data outside of defined boundaries.

Finally, authenticate network communications. Verify the identity of communications using protocols that support authentication, such as Transport Layer Security or IPsec.



1.26 Incident Response

The next security best practice area is incident response. Even with extremely mature preventive and detective controls, your organization should still put processes in place to respond to and mitigate the potential impact of security incidents. The architecture of your workload strongly affects the ability of your teams to operate effectively during an incident to isolate or contain systems and restore operations to a known good state.

1.27 Design goals of cloud response

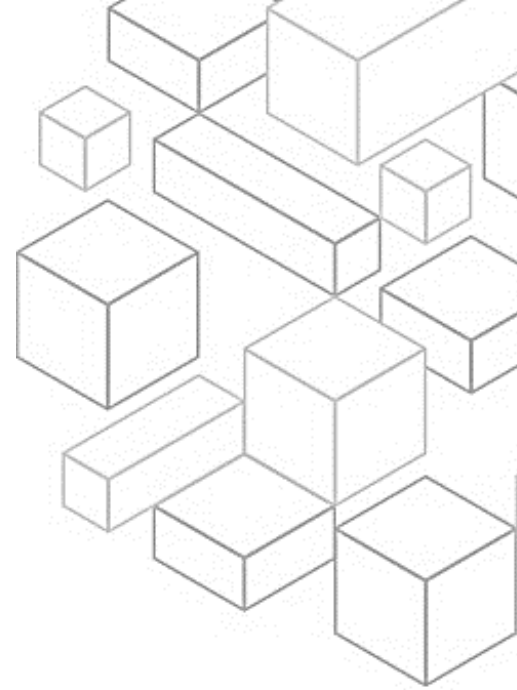
The general processes and mechanisms of incident response, such as those defined in the NIST SP 800-61 Computer Security Incident Handling Guide, are important. You should also evaluate the following design goals to help respond to security incidents in a cloud environment.

First, establish response objectives. Work with your stakeholders, legal counsel, and organizational leadership to determine the goal of responding to an incident. Some common goals include containing and mitigating the issue, recovering the affected resources, preserving data for forensics, and attribution.

Next, document plans. Create plans to help you respond to, communicate during, and recover from an incident.

Respond using the cloud: Implement your response patterns where the event and data occurs.

Know what you have and what you need. Preserve logs, snapshots, and other evidence by copying them to a centralized security cloud account. Use tags, metadata, and mechanisms that enforce retention policies. For example, you



might choose to use the Linux `dd` command or a Windows equivalent to make a complete copy of the data for investigative purposes.

Use redeployment mechanisms. If a security anomaly can be attributed to a misconfiguration, the remediation might be as fast as removing the variance by redeploying the resources with the proper configuration. When possible, make your response mechanisms safe to run more than once and in environments in an unknown state.

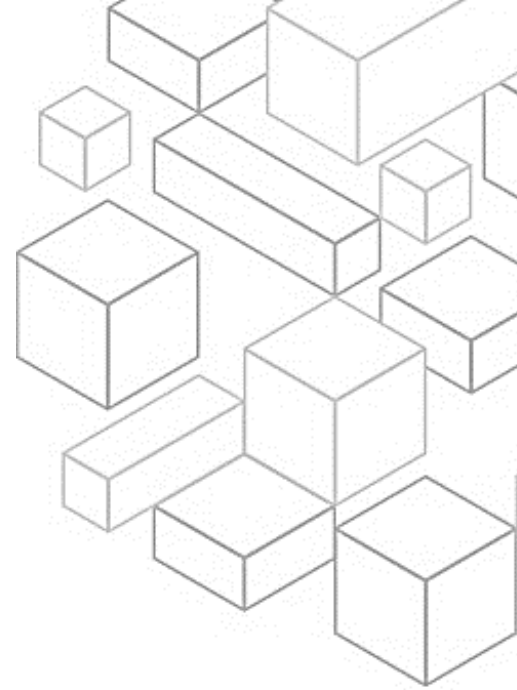
Automate where possible. As you notice issues or incidents that repeat, build mechanisms that programmatically triage and respond to common situations. Use human responses for unique, new, and sensitive incidents.

Choose scalable solutions. Strive to match the scalability of your organization's approach to cloud computing, and reduce the time between detection and response.

Finally, learn and improve your process. When you identify gaps in your process, tools, or people, implement plans to fix them. Simulations are safe methods to find gaps and improve processes.

1.28 Educate

Automated processes help organizations spend more time focusing on measures to increase the security of their workloads. Automated incident response also makes humans available to correlate events, practice simulations, devise new response procedures, perform research, develop new skills, and test or build new tools. Despite increased automation, your team, specialists, and responders in a security organization still require continuous



education. It is helpful to review and incorporate the following areas when thinking about educating your security teams.

To start, consider development skills. Equipping security professionals with programming skills can help accelerate your organization's automation efforts. This includes not only ensuring education on programming languages, such as Python, but also ensuring familiarity with source control system, version control, and continuous integration and continuous delivery, or CI/CD, processes. When developers have this understanding, they can increase efficiency and reduce errors when automating.

You can also train your team to be proficient with the security services offered by AWS. Understanding how to use cloud tools helps reduce response time and build team confidence. In addition, establish a cadence of education about new services and capabilities to continually iterate your capabilities. Just as the threat landscape changes, so do the tools.

Finally, maintain application awareness. Train your incident response team on the specifics of the workloads and environments that they own. This includes understanding what logs are emitted, what information logs contain, traffic flow of the application, and authentication and authorization mechanisms in use. This is a critical component because deep understanding of your organization's infrastructure and applications provides an advantage to protecting them. The best way to learn is hands-on, such as through running incident-response game days. This helps experts on your team hone the tools and techniques while teaching others. This is covered in more detail in the following section. Moving forward, remember to maintain the required training



for your entire organization. Security awareness is an important line of defense. All users should be trained to report suspicious behavior to your security team for further investigation.

1.29 Prepare, simulate, iterate

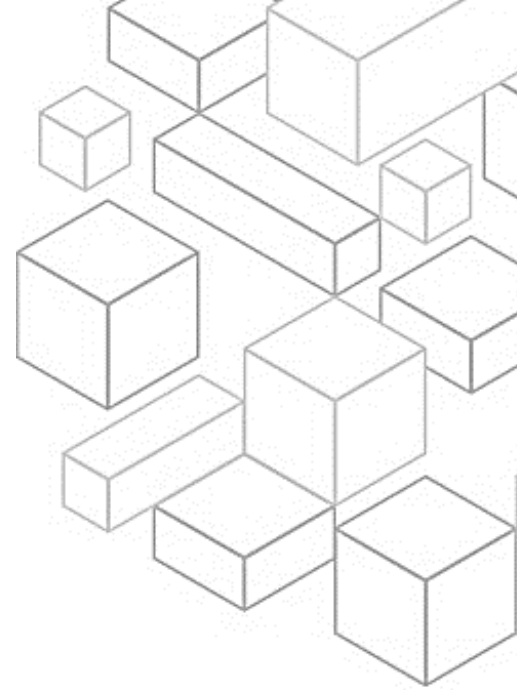
Be sure to consider pre-provision access. During an incident, your incident response teams must have access to various tools and workload resources involved in the incident. Verify that your teams have appropriate pre-provisioned access to perform their duties before an event occurs. All tools, access, and plans should be documented and tested to make sure that they can provide a timely response. Consider the following best practices.

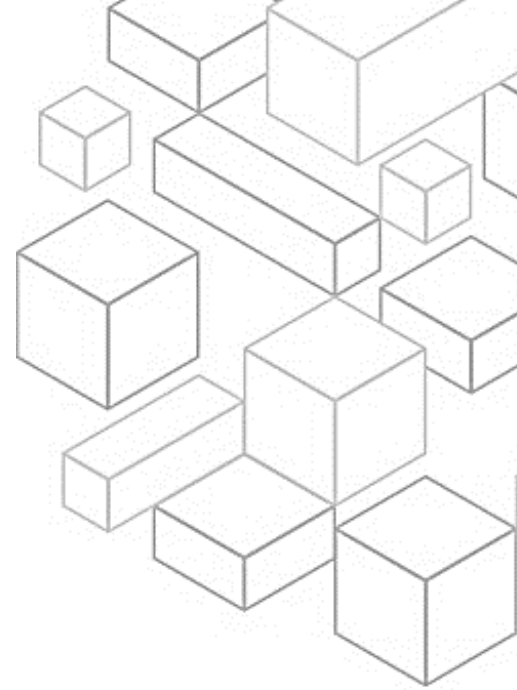
Identify key personnel and external resources. Seek out the internal and external personnel, resources, and legal obligations that would help your organization respond to an incident.

Develop incident management plans. Create plans to help you respond to, communicate during, and recover from an incident.

Next, prepare forensic capabilities. It's important for your incident responders to understand when and how forensic investigation fits into your response plan. Your organization should define what evidence is collected and what tools are used in the process. Identify and prepare forensic investigation capabilities that are suitable, including external specialists, tools, and automation.

Also consider how to automate the containment and recovery of an incident. This can help reduce response times and organizational impact. After you create and practice processes and tools from your playbooks, deconstruct the





logic into a code-based solution. This can be used as a tool by many responders to automate the response and remove variance or guesswork by your responders. You can also speed up the lifecycle of a response.

The next goal is to fully automate this code to be invoked by the alerts or events themselves, rather than by a human responder, to create an event-driven response. These processes should also automatically add relevant data to your security systems. For example, an incident involving traffic from an unwanted IP address can automatically populate an AWS WAF block list or AWS Network Firewall rule group to prevent further activity. For pre-provisioning access, verify that incident responders have the correct access pre-provisioned in AWS. This can help cut the time needed for investigation through to recovery. Also ensure that security personnel have the right tools pre-deployed into AWS to reduce the time for investigation through to recovery.

Finally, run game days, also known as simulations or exercises. These are internal events that provide a structured opportunity to practice your incident management plans and procedures during a realistic scenario. These events should exercise responders using the same tools and techniques that would be used in a real-world scenario. Game days can even mimic real-world environments. They are fundamentally about being prepared and iteratively improving your response capabilities.

1.30 Application Security

The last security best practice area is application security. Security is a topic that traverses all areas of technology. You already learned about identity,



infrastructure protection, data protection, and incident response. Next, you will learn about application security.

1.31 Application security

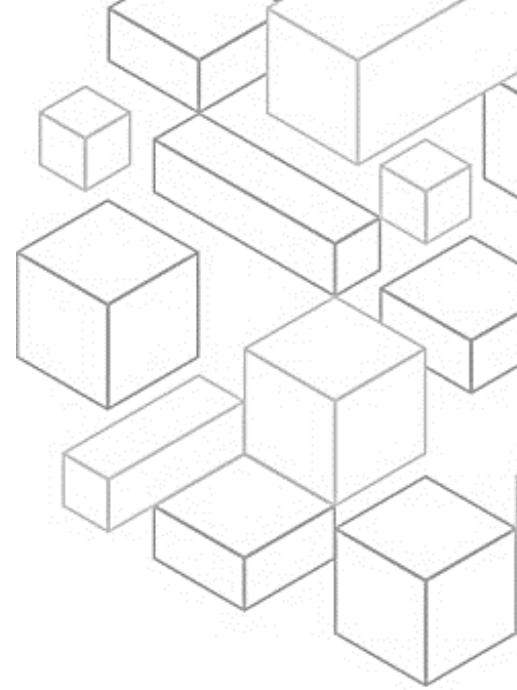
Training people, testing using automation, understanding dependencies, and validating the security properties of tools and applications help reduce the likelihood of security issues in production workloads.

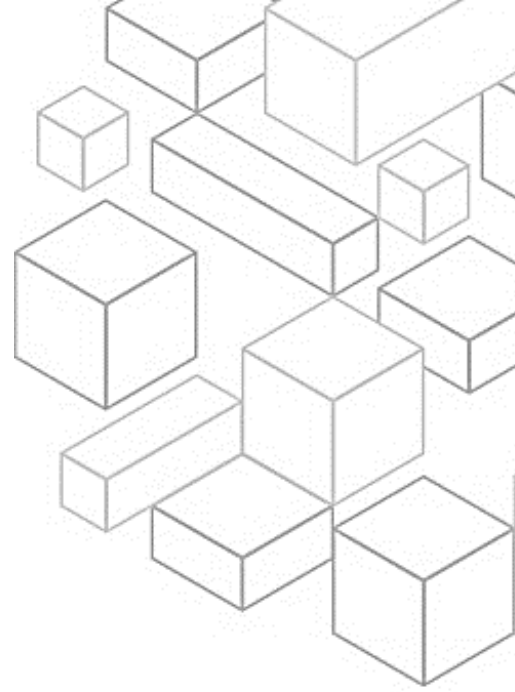
It's important to train for application security. Provide training to the builders in your organization on common practices for the secure development and operation of applications. Adopting security-focused development practices helps reduce the likelihood of issues that are only detected at the security review stage.

Automate testing throughout the development and release lifecycle, including for security properties throughout the development and release lifecycle. Automation helps you consistently and repeatedly identify potential issues in software before release. This can reduce the risk of security issues in the software being provided.

Perform regular penetration testing of your software. This mechanism helps identify potential software issues that cannot be detected by automated testing or a manual code review. It can also help you understand the efficacy of your detective controls. Penetration testing should try to determine if the software can be made to perform in unexpected ways, such as exposing data that should be protected or granting broader permissions than expected.

Perform a manual code review of the software that you produce. This process helps verify that the person who wrote the code is not the only one checking the code quality.





Centralize services for packages and dependencies. Provide centralized services for builder teams to obtain software packages and other dependencies. This validates packages before they are included in the software that you write and provides a source of data for software analysis.

Perform software deployments programmatically where possible. This approach reduces the likelihood that a deployment fails or an unexpected issue is introduced due to human error.

Regularly assess security properties of the pipelines. Apply the principles of the AWS Well-Architected security pillar to your pipelines, with particular attention to the separation of permissions. Regularly assess the security properties of your pipeline infrastructure. Effectively managing the security of the pipelines helps you deliver the security of the software that passes through the pipelines.

Finally, build a program that embeds security ownership in workload teams. Empower builder teams to make security decisions about the software that they create. Your security team still needs to validate these decisions during a review, but embedding security ownership in builder teams leads to building faster, more secure workloads. This mechanism also promotes a culture of ownership that positively impacts the operation of the systems you build.

1.35 Summary

In this module, you learned about the security pillar. This started with an overview and included in depth discussion on the value proposition, design principles, and best practices of the security pillar.



1.36 Thank you

Thank you for your participation!

